EVERYDAY DENTAL SURGERY
& IMPLANT CENTER

Complete Project Documentation

HIPAA-Compliant | FHIR R4 Interoperable | SOC 2 Ready
Progressive Web App | Bilingual (English/Bengali)

Version 1.0 | April 2026

TABLE OF CONTENTS

1. Project Overview3
2. Key Features4
3. Technology Stack6
4. System Architecture7
5. Healthcare Compliance8
6. Security Implementation10
7. Admin Panel11
8. Patient Portal12
9. Pages & Routes13
10. Database Design14
11. API & Edge Functions15
12. UI/UX Design System16
13. Deployment & DevOps17

1. PROJECT OVERVIEW

Everyday Dental Surgery & Implant Center is a full-stack, production-grade web application built for a real dental clinic in Dhaka, Bangladesh. It serves as both a public-facing marketing website and a comprehensive healthcare management platform with patient portal, admin dashboard, and clinical data management.

The application is designed from the ground up to meet international healthcare compliance standards including HIPAA (Health Insurance Portability and Accountability Act), FHIR R4 (Fast Healthcare Interoperability Resources), and SOC 2 Trust Service Criteria, making it one of the most compliance-focused dental clinic applications in the region.

20+ Pages	**9** Edge Functions	**9** DB Migrations	**4** User Roles
11 SOC 2 Policies	**6** FHIR Resources	**2** Languages	**AES-256** Encryption

Project Identity

Name: Everyday Dental Surgery & Implant Center (EDS Dental)

Type: Full-Stack Healthcare SPA (Single Page Application)

Doctor: Dr. Arman Hossain (Rafi) — BDS, Dental Surgeon

Location: Dhaka, Bangladesh

Domain: dental-clinic-anq.pages.dev (Cloudflare Pages)

Category: Health & Medical

2. KEY FEATURES

Public Website Features

- Dynamic homepage with hero section, service showcase, testimonials, video gallery, and statistics counters
- Detailed service pages for each dental treatment with procedure steps, benefits, recovery info, and pricing (bilingual)
- Online appointment booking with form validation, date/time selection, and medical notes field
- Patient registration with medical history, blood group, allergies, and emergency contact collection
- Blog system with individual post pages and SEO-optimized metadata
- Interactive pricing page with treatment categories and cost ranges
- Photo gallery showcasing clinic facilities and equipment
- Conference and community pages for professional networking
- Contact form with WhatsApp floating button integration
- FAQ page with searchable accordion interface
- Privacy Policy and Terms of Service pages (legally compliant)
- Newsletter subscription with email notification

Patient Portal Features

- Secure login with email/password authentication and phone OTP verification
- Personal profile management with encrypted medical data viewing
- Appointment history with status tracking (pending, confirmed, completed, cancelled)
- Medical data viewer showing conditions, allergies, and treatment history
- FHIR R4 data export — one-click download of complete medical records as a FHIR Bundle
- Data rights management: submit access, amendment, deletion, and restriction requests (HIPAA 164.524)
- Automatic 15-minute inactivity logout with warning modal (HIPAA-compliant)
- Password recovery via email with secure reset tokens

Admin Dashboard Features

- Overview dashboard with appointment, registration, contact, and user statistics
- Appointment management with search, filter, and status updates
- Patient registration review with encrypted PHI decryption for authorized staff
- Contact form submissions viewer with resolution tracking
- Newsletter subscriber management with export capabilities
- Immutable audit log viewer with filters by action, user, table, and date range
- Patient data access request queue with approve/deny workflow
- User management: create, deactivate, change roles (patient, doctor, receptionist, admin)
- Data retention policy configuration with configurable retention periods per table

- Security incident dashboard with breach detection, severity tracking, and investigation workflow
- Receptionist-safe views that automatically exclude PHI columns (medical history, allergies, etc.)

Bilingual Support (i18n)

Every text string in the application supports both English and Bengali using an inline object pattern { en: "...", bn: "..." } with a t() translation function from LanguageContext. This includes all pages, forms, error messages, button labels, service descriptions, navigation, and admin interface. Users can switch languages instantly via a toggle in the navigation bar. No external translation files are needed — all translations are co-located with the component code for easy maintenance.

3. TECHNOLOGY STACK

Frontend

Technology	Purpose
React 18	Core UI library with functional components, hooks, and lazy loading
Vite 5	Lightning-fast build tool with HMR, code splitting, and tree shaking
React Router v6	Client-side routing with nested routes and protected route guards
Tailwind CSS 3.4	Utility-first styling with custom design tokens (navy, teal, gold palette)
Framer Motion	Page transitions, hover/tap micro-interactions, AnimatePresence
GSAP + ScrollTrigger	Scroll-driven animations, parallax effects, stagger reveals
Lenis	Buttery-smooth scroll synchronized with GSAP ticker
React Hook Form	Performant form handling with validation
Lottie React	Lightweight vector animations for loading and UI delight
Lucide React	Consistent, tree-shakeable icon library (200+ icons used)
React Helmet Async	Dynamic SEO meta tags per page
React Hot Toast	Accessible notification toasts for form submissions and errors
DOMPurify	XSS protection — sanitizes all user input before rendering

Backend (Supabase)

Technology	Purpose
Supabase (PostgreSQL)	Database with Row-Level Security, pgcrypto encryption, Vault secrets
Supabase Auth	Email/password + phone OTP authentication, JWT sessions, auto-refresh
Edge Functions (Deno)	9 serverless functions for form handling, FHIR API, admin queries, breach detection
Supabase Vault	Secure storage for AES-256 encryption keys (PHI protection)
Resend API	Transactional email delivery (HIPAA-safe — no PHI in email body)

Infrastructure & DevOps

Technology	Purpose
Cloudflare Pages	Static SPA hosting with global CDN, DDoS protection, and custom headers
PWA (Service Worker)	Offline-capable progressive web app with installable manifest
Custom _headers	Security headers (CSP, HSTS, COOP, COEP, Permissions-Policy)

Compliance Scanner	Built-in npm audit scripts for HIPAA, FHIR, SOC 2, and security checks

4. SYSTEM ARCHITECTURE

High-Level Architecture

The application follows a modern serverless architecture pattern with clear separation between the client-side SPA and the Supabase backend services. All communication happens over HTTPS with JWT-based authentication.

Request Flow

Browser (React SPA) → Cloudflare Pages (CDN + Headers) → Supabase Auth (JWT) → Edge Functions (Deno) → PostgreSQL (RLS + Encryption) → Audit Log Trigger → Notification (Resend Email)

Three-Tier Animation System

- Tier 1: GSAP + ScrollTrigger — scroll-driven reveals, parallax effects, staggered animations
- Tier 2: Framer Motion — page transitions (AnimatePresence), hover/tap micro-interactions
- Tier 3: Tailwind Keyframes — marquee, float, shimmer, pulse-teal, glow-pulse CSS animations

Lenis smooth scrolling is synchronized to the GSAP ticker in App.jsx for perfectly fluid scroll behavior across all animation tiers.

Layout Structure

The app renders: AnnouncementBar → Navbar (fixed) → Main content area (with pt-[100px] md:pt-[116px] for header clearance) → Footer, plus BackToTop and WhatsAppFloat overlay components. All pages are lazy-loaded via React.lazy() for optimal initial bundle size.

Role-Based Access Control (RBAC)

Role	Can Access	Can Modify	PHI Access
Patient	Own profile, appointments, medical data, FHIR export	Own profile, submit forms	Own data only (decrypted)
Doctor	All patient data, admin panel, clinical records	Appointments, medical notes	Full (decrypted views)
Receptionist	Admin panel, appointments, contacts	Appointment status	Limited (PHI excluded)
Admin	Everything + user management, audit logs, security	All data, roles, policies	Full + audit trail

5. HEALTHCARE COMPLIANCE

5.1 HIPAA Compliance

The application implements technical safeguards required by the HIPAA Security Rule (45 CFR 164), specifically designed for Protected Health Information (PHI) handling in a dental clinic context.

PHI Encryption at Rest: All sensitive fields (medical_history, allergies, date_of_birth, blood_group, medical_notes) encrypted using pgcrypto AES-256 with keys stored in Supabase Vault

Row-Level Security (RLS): Every database table has RLS policies enforced. Patients see only their own data. Staff access controlled by role. SECURITY DEFINER helper functions prevent privilege escalation

Audit Logging: Immutable audit_logs table with triggers on all PHI tables. Logs user, timestamp, action, table, record, old/new values. PHI automatically stripped from log entries

Session Management: 15-minute inactivity auto-logout with 1-minute warning modal. Activity tracked on mousedown, keydown, touchstart, scroll events

Breach Detection: 6 configurable anomaly detection rules: excessive PHI access, non-staff access, after-hours access, bulk export, failed auth spike, role escalation. Automated incident creation with 60-day HIPAA notification deadline

Consent Tracking: Immutable consent_records table tracking consent type, version, IP address, user agent, and revocation history

Data Retention: Configurable retention policies per table (default 7 years for PHI per HIPAA). Automated purge function with purge_logs for compliance evidence

Safe Notifications: Email notifications never include PHI — only reference numbers with portal login links. Security footer on all emails

Patient Data Rights: FHIR R4 export for Right to Access (164.524). Data access, amendment, deletion, and restriction request workflow

5.2 FHIR R4 Interoperability

The application implements HL7 FHIR R4 (Fast Healthcare Interoperability Resources) for structured clinical data exchange, enabling integration with Electronic Health Records (EHR) systems and healthcare networks.

Implemented FHIR Resources

Resource	Description	Terminology
Patient	Demographics, identifiers, telecom, blood group extension	Custom identifier system
Appointment	Booking status, service type, participants, date/time	SNOMED CT service codes
AllergyIntolerance	Patient allergies with clinical/verification status	SNOMED CT allergy codes
Condition	Medical conditions with dual coding	SNOMED CT + ICD-10-CM
Practitioner	Doctor profiles with qualifications	SNOMED CT practitioner roles

Organization	Clinic details, contact information	HL7 organization type

FHIR REST API Endpoints

- GET /fhir/metadata — CapabilityStatement (public)
- GET /fhir/Patient/:id — Read patient resource (auth required)
- GET /fhir/Appointment?patient=X&status=Y — Search appointments
- GET /fhir/AllergyIntolerance?patient=X — Search allergies
- GET /fhir/Condition?patient=X — Search conditions
- GET /fhir/Practitioner/:id, Organization/:id — Read clinical context
- POST /fhir/export — Patient FHIR Bundle export (HIPAA Right to Access)

Terminology Bindings

SNOMED CT codes validated for: 8 dental services (checkup, prophylaxis, whitening, root canal, extraction, crown, orthodontics, periodontology), 4 common allergies (penicillin, latex, aspirin, local anesthesia), 6 medical conditions (diabetes, heart disease, hypertension, asthma, epilepsy, kidney disease), and 5 practitioner qualifications (dentist, orthodontist, endodontist, periodontist, oral surgeon). ICD-10-CM codes mapped for all conditions.

5.3 SOC 2 Compliance

11 comprehensive policy documents covering all 5 Trust Service Criteria, stored in docs/policies/:

Policy Document	Coverage
Access Control Policy	Role definitions, authentication, deprovisioning, privilege management
Information Security Policy	Password requirements, encryption standards, network security
Incident Response Plan	Detection, investigation, containment, notification, post-incident review
Business Continuity Plan	RTO/RPO targets, backup strategy, failover procedures
Change Management	Change request workflow, approval, rollback procedures
Data Classification	PHI, PII, internal, public data handling rules
Risk Assessment	Threat identification, vulnerability analysis, risk mitigation matrix
Privacy Impact Assessment	PHI data flow analysis, consent requirements, patient rights
Security Training	Annual training requirements, phishing awareness, incident reporting
Vendor Management	Third-party risk assessment, BAA requirements, review schedule
BAA Checklist	Business Associate Agreement tracking for Supabase, Resend, Cloudflare

6. SECURITY IMPLEMENTATION

Defense-in-Depth Security Layers

Layer 1: Network: Cloudflare CDN with DDoS protection, HSTS (max-age 1 year), TLS 1.3 enforcement

Layer 2: HTTP Headers: Content-Security-Policy, X-Frame-Options: DENY, X-Content-Type-Options: nosniff, Cross-Origin Isolation (COOP/COEP), Permissions-Policy (disable camera, mic, geolocation, payment, USB)

Layer 3: Authentication: Supabase Auth with email/password + phone OTP. JWT tokens with auto-refresh. 15-minute HIPAA-compliant session timeout

Layer 4: Authorization: Row-Level Security on every table. SECURITY DEFINER helper functions. Role-based route protection with ProtectedRoute component

Layer 5: Input Validation: Client-side: DOMPurify sanitization + React Hook Form validation. Server-side: Edge Function sanitization + regex validation

Layer 6: Encryption: AES-256 encryption at rest via pgcrypto. Vault-managed encryption keys. HTTPS in transit. No source maps in production

Layer 7: Monitoring: Immutable audit logs. 6 anomaly detection rules. Security incident dashboard. Breach notification workflow with 60-day HIPAA deadline

Compliance Audit Scanner

The project includes a built-in compliance audit tool accessible via npm scripts. This scanner checks HIPAA controls, FHIR R4 implementation, SOC 2 policy coverage, security headers, and data flow integrity. It can be run as a CI/CD deploy gate (npm run audit:ci) to block deployments that fail critical compliance checks.

7. ADMIN PANEL

The admin panel is a comprehensive management interface accessible to admin, doctor, and receptionist roles. It provides 10 distinct management modules:

Overview Dashboard: Real-time statistics for appointments, registrations, contacts, and users. Visual cards with trend indicators

Appointments: Full appointment listing with search, filter, and status management. Encrypted medical notes visible to doctors/admins only

Registrations: Patient registration submissions with medical history, allergies, and blood group. Encrypted PHI decrypted for authorized staff

Contacts: Contact form submissions with read/unread status and resolution tracking

Newsletter: Subscriber management with email list and subscription dates

Audit Logs: Immutable log viewer with filters by action type, user, table, and date range. PHI automatically stripped from records

Data Requests: Patient data access/amendment/deletion/restriction request queue with approve/deny workflow and admin notes

User Management: Create/deactivate users, assign roles, view last login, manage MFA enrollment

Retention Policies: Configure data retention periods per table. View purge history and upcoming expirations

Security Incidents: Breach detection dashboard with severity levels (low/medium/high/critical), investigation status tracking, containment actions, and manual breach check trigger

8. PATIENT PORTAL

The patient portal provides a secure, HIPAA-compliant interface for patients to manage their healthcare data. It consists of 5 tabs:

Profile: View and manage personal information including name, email, phone, and role. Displays account creation date and last login

Appointments: View appointment history with status badges (pending, confirmed, completed, cancelled). Shows date, time, service type, and reference number

Medical Data: View encrypted medical records including conditions, allergies, medical history, and blood group. Data decrypted on-demand with proper authorization

Export (FHIR): One-click FHIR R4 Bundle export containing Patient demographics, all Appointments, AllergyIntolerances, Conditions, and Organization/Practitioner context. Implements HIPAA 164.524 Right to Access

Data Rights: Submit formal data access, amendment, deletion, or restriction requests per HIPAA patient rights. Track request status (pending, in progress, completed, denied) with admin response notes

9. PAGES & ROUTES

Public Pages (17)

Route	Component	Description
/	HomePage	Hero, services, testimonials, video gallery, stats, CTA
/about	AboutPage	Doctor profile, clinic story, mission
/services	ServicesPage	All dental services grid
/services/:slug	ServiceDetailPage	Individual service detail with procedures, benefits, pricing
/pricing	PricingPage	Treatment pricing table
/blog	BlogPage	Blog listing
/blog/:slug	BlogPostPage	Individual blog post
/faq	FAQPage	Searchable FAQ accordion
/contact	ContactPage	Contact form + WhatsApp + map
/register	RegisterPage	Patient registration with medical history
/appointment	AppointmentPage	Online appointment booking
/gallery	GalleryPage	Clinic photo gallery
/community	CommunityPage	Community engagement
/conferences	ConferencesPage	Professional conferences
/privacy-policy	PrivacyPolicyPage	HIPAA-compliant privacy policy
/terms	TermsPage	Terms of service

Auth Pages (5)

/login, /signup, /forgot-password, /reset-password, /unauthorized

Protected Pages

/dashboard/* — Patient portal (requires authentication)

/admin/* — Admin panel (requires admin, doctor, or receptionist role)

10. DATABASE DESIGN

PostgreSQL database with 9 sequential, idempotent migrations covering schema, RBAC, encryption, audit logging, consent tracking, FHIR resources, data retention, and breach notification.

Core Tables

Table	Description
user_profiles	User accounts with role, MFA status, active flag, linked to Supabase Auth
appointments	Appointment bookings with encrypted medical_notes_enc, reference numbers, timestamps
registrations	Patient registrations with encrypted medical_history_enc, allergies_enc, date_of_birth_enc, blood_group_enc
contacts	Contact form submissions with name, phone, email, message
newsletter_subscribers	Email newsletter subscriptions
audit_logs	Immutable append-only audit trail (INSERT/UPDATE/DELETE on all PHI tables)
consent_records	Immutable consent tracking with type, version, IP, user agent, revocation
data_access_requests	Patient rights requests (access, amendment, deletion, restriction)
fhir_resources	JSONB storage for FHIR R4 resources with versioning and source tracking
retention_policies	Per-table retention periods with last_purged tracking
purge_logs	Immutable record of all data purge operations
security_incidents	Security incidents with severity, status, affected users, containment actions
anomaly_rules	Configurable breach detection rules with thresholds

Key Database Features

- Row-Level Security (RLS) on every table with role-based policies
- pgcrypto AES-256 encryption with Vault-managed keys for all PHI columns
- SECURITY DEFINER helper functions: auth.user_role(), auth.is_admin(), auth.is_staff()
- Automatic audit log triggers with PHI auto-stripping from logged values
- Immutable tables (audit_logs, consent_records, purge_logs) — no UPDATE or DELETE allowed
- GIN index on FHIR JSONB column for fast resource queries
- Decrypted views for authorized access, receptionist-safe views excluding PHI

11. API & EDGE FUNCTIONS

9 Deno-based Supabase Edge Functions handle server-side logic, providing validation, authorization, and secure data processing.

submit-form: Receives contact, appointment, registration, and newsletter submissions. Validates, sanitizes, encrypts PHI, and inserts into database. Triggers notification email

send-notification: Sends transactional emails via Resend API. PHI-safe — emails contain only reference numbers and portal links. Handles appointment confirmations and admin alerts

admin-query: Authenticated admin data retrieval with role-based view selection. Receptionists get PHI-excluded views; doctors/admins get decrypted views. Supports pagination, filtering, and sorting

admin-manage-user: User CRUD operations: create with role assignment, deactivate/reactivate accounts, change roles. Admin-only access

admin-resolve-request: Process patient data access requests: approve, deny, or mark in-progress with admin notes and resolution timestamp

get-patient-data: Retrieves patient profile, appointments, and medical data with consent verification. Staff can query any patient; patients query own data only

fhir-api: FHIR R4 REST endpoints: GET for Patient, Appointment, AllergyIntolerance, Condition, Practitioner, Organization. CapabilityStatement at /metadata. Role-based access

fhir-export: Generates complete FHIR R4 Bundle for patient data export. Includes Patient, Appointments, AllergyIntolerances, Conditions, Organization, and Practitioner context. Logs export to audit trail

breach-check: Runs 6 anomaly detection rules against audit_logs: excessive PHI access, non-staff access, after-hours access, bulk export, failed auth spike, role escalation. Creates security incidents and sends admin alerts

Shared Utilities

- _shared/sanitize.ts — Server-side input sanitization matching client-side DOMPurify patterns
- _shared/rate-limit.ts — IP-based rate limiting for Edge Functions

12. UI/UX DESIGN SYSTEM

Brand Color Palette

Navy #0A1628	Teal #00BFA6	Gold #D4AF37	Offwhite #F8FAFC

Typography

Headings: Plus Jakarta Sans — modern geometric sans-serif for a clean, professional look

Body: Inter — highly legible at all sizes, optimized for screen reading

Custom UI Components

TiltCard: 3D perspective tilt effect on hover with configurable intensity (default 15°)

MagneticButton: Cursor-following magnetic offset effect with configurable strength (0.3)

CursorGlow: 400px teal radial gradient following cursor movement across the page

Glass-morphism: Frosted glass card effects with backdrop-blur and semi-transparent backgrounds

ScrollStory: Scroll-driven storytelling component with GSAP-powered section transitions

RunningTooth: Animated tooth character that runs across the screen — a playful dental-themed easter egg

DentalDivider: Custom wave/tooth-shaped section dividers for visual storytelling

Dental3DObject: CSS 3D tooth and implant objects with morph animations

ToothReveal: Scroll-triggered parallax 3D tooth reveal animations

CounterStat: Animated number counter with intersection observer trigger

ErrorBoundary: Graceful error handling with user-friendly fallback UI

LoadingScreen: Animated dental-themed loading screen on initial app load

13. DEPLOYMENT & DEVOPS

Build & Deploy Pipeline

- Vite 5 production build with tree-shaking, code splitting, and no source maps (sourcemap: false)
- Lazy-loaded routes reduce initial bundle — each page is a separate chunk
- Static SPA deployed to Cloudflare Pages with global CDN distribution
- Custom _headers file configures security headers at the CDN edge level
- PWA manifest (manifest.json) enables app installation on mobile devices
- Service worker (sw.js) provides offline caching for static assets

Compliance CI/CD Gate

The project includes a compliance audit scanner that can be integrated into CI/CD pipelines. Running npm run audit:ci performs a full compliance check across HIPAA, FHIR R4, SOC 2, and security headers, exiting with code 1 if any critical failures are detected. This ensures compliance is maintained with every deployment.

Available Audit Commands

- npm run audit:compliance — Full audit across all categories
- npm run audit:ci — CI/CD gate (exits 1 on critical failures)
- npm run audit:json — Machine-readable JSON report
- npm run audit:hipaa — HIPAA-specific checks only
- npm run audit:fhir — FHIR R4 checks only
- npm run audit:soc2 — SOC 2 checks only
- npm run audit:security — Security header checks only

Everyday Dental Surgery & Implant Center

A complete, compliance-first dental clinic platform

Built with React 18 | Supabase | Cloudflare Pages | HIPAA | FHIR R4 | SOC 2